

Assessment tool-3 [CO1]

Name :- K. Jahnavi Sai Satya

REG NO :- 192372312

DEPARTMENT :- CSE-AI

COURSE :- Ethical Hacking

CODE :- ITAI405

Ethical Resolution Between Contractual Obligation and Patient safety

Scenario:- During a penetration test, I discover a critical vulnerability. Exploiting it completely, as required by the contract could crash the hospital's Management Patient Systems. This creates a conflict between fulfilling the contract and ensuring the safety.

ethical Dilemma:- this situation presents two conflicting responsibilities.

1) Contractual Obligation: The contract requires complete exploitation of vulnerability to verify its severity and demonstrate its impact. This helps the client understand the actual risk and implement appropriate security measures.

2) Patient safety: Performing full exploitation on the live hospital system could interrupt patient monitoring services, delay emergency alerts or affect critical healthcare operations. This could put patients at serious risk.

As an ethical hacker, I must balance these two responsibilities and choose the safest action.

Ethical Decision :- I would not perform full exploitation on the live hospital system because patient survey is more important than completing every testing requirement.

→ Ethical hacking follows the principle of "DO NO HARM" meaning that security testing should never create unnecessary risks to people or essential services.

Instead, I would choose a safer method to verify the vulnerability while ensuring that hospital operations continue without interruption.

Steps to Resolve the Conflict :-

1) Stop Further Exploitation :-

→ Immediately stop testing on affected live system.

→ Prevent accidental crashes or service interruptions.

→ Ensure the patient care is not affected.

2) Inform the client immediately :-

→ Notify :- Hospital Management.

→ security team → Project Manager

→ IT Administrators.

Explain about :- 1) The vulnerability discovered

2) the severity of the issue

3) the risks of Continuing exploitation.

4) why testing has been paused.

3) Provide Technical Evidence :- Instead of full exploitation, collect evidence such as screenshots, log files, vulnerability scanner reports, configuration details, limited proof of concept demonstrations, error messages.

Purpose :- Prove that vulnerability exists and also avoid causing damage to the live system.

4) step 4 :- Request a Safe Testing Environment
Recommend the staging in following areas :-

→ staging Environment

→ sandbox Environment

→ test laboratory

Perform exploitation only in the test environment and also ensure there is

no impact on real hospital operations.

5) Document Everything :- Proper documentation is an important thing in ethical hacking.

My report would include :-

1. Details of the vulnerability
2. systems affected
3. Potential impact
4. Evidence collected
5. Reason for stopping exploitation
6. Recommended security fixes
7. Alternative testing methods.

this documentation provides transparency and helps the client resolve the issue effectively.

6) Escalate if necessary :- Escalate the issue to senior management or legal representatives. I would recommend modifying the testing scope to ensure patient safety.

If the risk remains unacceptable, I would refuse to perform the dangerous test because protecting human life is more important than fulfilling a contractual requirement.

7) Ethical Principles Applied :-

Patient Safety First :- Human life should always be highest priority during an security assessment of patient records.

Do No Harm :- Ethical hackers must avoid actions that could damage systems or interrupt critical healthcare services.

Professional Responsibility :- Security Professionals must follow established ethical standards, industry best practices and professional code of conduct. They should make decisions that protect both organization and the public.

Responsible Disclosure :- Vulnerabilities should be reported honestly, accurately and promptly to authorised personnel. Responsible disclosure ensures that security issues are fixed before malicious attackers can exploit them.

Risk Management :- Every penetration test should include continuous risk assessment, if testing becomes dangerous safer alternatives should be selected without compromising the patient safety.

Accountability :- Ethical hackers should accept responsibility for their decisions, maintain complete documentation and ensure that all actions are transparent and professionally justified.

Alternative :- Instead of exploiting the live system directly :-

- validate the vulnerability in staging environment
- perform a non destructive proof of concept
- simulate the attack safely
- Apply temporary security controls.
- Recommend immediate patching
- Monitor the system after remediation.

Conclusion :- Although the contract requires full exploitation, an ethical hackers first responsibility is to protect human and prevent harm. I would immediately report vulnerability, avoid risky testing on live hospital system, verify it using safe methods and document all findings. By following ethical principles and responsible security practices, I can help improve the hospital's security without compromising patients safety.